



Q1. Explain the concept of an Information System and describe its major components.

(Module 1 – Question 1)

Definition

An **Information System (IS)** is a coordinated collection of resources used to collect, process, store and distribute information to support the activities and objectives of an organization.

Six Major Components

1. **Hardware** – Physical devices such as computers, servers, storage devices and networking equipment.
2. **Software** – Programs and applications that process data and perform required tasks.
3. **People** – Users, employees, administrators and other individuals who use and manage the system.
4. **Procedures** – Rules, methods and processes that specify how the system should be operated.
5. **Communication Networks** – Networks that connect devices and enable communication and information sharing.
6. **Data** – Raw facts and information stored and processed by the system.

Conclusion

All six components work together to collect, process, store and communicate information effectively. Therefore, each component is important for the proper functioning and security of an Information System.



Q2. A university stores student marks, attendance and personal information in an online system. Explain how Confidentiality, Integrity and Availability can be applied to protect this information.

Question Bank – Module 1, Q4

Answer:

The **CIA Triad** is the foundation of Information Security and consists of **Confidentiality, Integrity and Availability**. All three principles must work together to keep information secure, accurate and accessible.

1. Confidentiality

Confidentiality means protecting information from **unauthorized access or disclosure**. Only authorized students, faculty and administrators should be allowed to access the required information.

Application in university system:

- Use usernames and strong passwords.
- Enable **Multi-Factor Authentication (MFA)** for sensitive accounts.
- Apply role-based access control.
- Encrypt sensitive student information.
- Prevent students from accessing other students' personal records.

Example: A student should be able to view their own marks but should not be able to view another student's marks or personal information.

2. Integrity

Integrity ensures that information remains **accurate, complete, consistent and protected from unauthorized modification**.

Application in university system:

- Only authorized faculty should be allowed to modify marks and attendance.
- Use access controls to restrict modification rights.
- Use hashing or digital signatures where required to detect unauthorized changes.
- Maintain audit logs of important activities.

- Regularly verify stored data.

Example: If a student's mark is 82, an unauthorized person must not be able to change it to 98. Such unauthorized modification would violate integrity.

3. Availability

Availability means that information and systems should remain **accessible to authorized users whenever required**.

Application in university system:

- Maintain regular backups.
- Use reliable servers and network infrastructure.
- Implement disaster recovery mechanisms.
- Protect systems against DoS attacks.
- Use redundant systems where necessary.
- Perform regular maintenance.

Example: Students should be able to access their marks and attendance during result publication without unnecessary system downtime.



Q3. Differentiate between Authentication and Non-Repudiation and analyze their importance in an online transaction system.

Q-7 M1

Difference between Authentication and Non-Repudiation

No. Authentication	Non-Repudiation
1 Verifies the identity of a user.	Provides proof of a user's action or transaction.
2 Answers “Who are you?”	Ensures that the user cannot deny the action .
3 Confirms that the user is genuine.	Confirms that a particular party performed the action.

No.	Authentication	Non-Repudiation
4	Uses passwords, OTPs, biometrics, etc.	Uses digital signatures, PKI, certificates, hashes, audit logs and timestamps.
5	Mainly prevents unauthorized access.	Mainly provides accountability and prevents false denial.
6	Usually occurs before accessing a system or performing a transaction.	Provides evidence about an action or transaction.
7	Protects accounts from unauthorized users.	Protects against denial of previously performed actions.
8	Example: OTP verifies a customer's identity.	Example: Digital signature proves approval of a transaction.
9	Important for login and access control.	Important for evidence, accountability and dispute resolution.
10	Ensures the right person accesses the system.	Ensures the person cannot deny the performed transaction.

Q4. An online banking system is unavailable for three hours because of a cyberattack. Analyze the possible financial, operational, customer, reputational and legal impacts of the disruption.

Question Bank – Module 2, Q8

Answer:

If an online banking system becomes unavailable for three hours due to a cyberattack, the disruption can affect the bank financially, operationally and legally, while also affecting customers and the bank's reputation.

1. Financial Impact

- Loss of transaction revenue during the outage.
- Customers may be unable to make payments or transfers.
- The bank may have to spend money on incident investigation and recovery.

- Compensation or refunds may be required in certain situations.
- Long-term financial losses may occur if customers move to competitors.

2. Operational Impact

- Online banking services become unavailable.
- Employees may be unable to perform normal banking operations.
- Transaction processing and other business activities may be delayed.
- IT teams must spend resources on detecting, containing and recovering from the attack.
- Business continuity can be affected.

Information Security supports business continuity through **backup strategies, disaster recovery plans, redundant systems and incident response procedures.**

3. Customer Impact

- Customers may not be able to access their accounts.
- Fund transfers and online payments may be delayed.
- Customers may experience inconvenience and dissatisfaction.
- If personal or financial information is compromised, customers may face additional security risks.

4. Reputational Impact

- Customers may lose confidence in the bank's ability to protect its systems.
- Negative publicity may affect the organization's reputation.
- Existing customers may consider changing service providers.
- Business relationships and customer trust may be affected.

5. Legal and Compliance Impact

- A security incident involving sensitive financial information may create legal and regulatory obligations.
- Failure to maintain appropriate security controls can result in penalties or legal action.
- Organizations are expected to protect sensitive personal and financial information and comply with applicable regulations.

Security Measures

The bank can reduce such risks by implementing:

- Strong authentication and MFA
 - Firewalls and intrusion detection systems
 - Encryption
 - Regular vulnerability assessments
 - Penetration testing
 - Regular backups and disaster recovery
 - Continuous monitoring and audit logging
 - Incident response procedures
-



Q5. Develop a basic threat model for an online examination system by identifying the assets, threats, vulnerabilities, attack vectors, possible impacts and appropriate mitigation measures.

Question Bank – Module 2, Q10

Answer:

A **threat model** is a structured approach to identifying the assets that need protection, possible threats, vulnerabilities, attack vectors and impacts, followed by suitable mitigation measures.

For an online examination system, the threat model can be represented as:

Assets → Threats → Vulnerabilities → Attack Vectors → Impacts → Mitigation

1. Assets

Important assets of an online examination system include:

- Student accounts and credentials
- Examination question papers
- Student answers and submissions
- Marks and examination results

2. Threats using STRIDE

STRIDE

S – Spoofing

T – Tampering

R – Repudiation

I – Information Disclosure

D – Denial of Service

E – Elevation of Privilege

3. Vulnerabilities

Possible weaknesses include:

- Weak passwords
- Poor access controls
- Unpatched software
- Insecure application configurations
- Inadequate backup mechanisms

The module identifies weaknesses such as **weak passwords, unpatched software and open ports** as examples of vulnerabilities.

4. Attack Vectors

Attackers may use different methods to exploit the system, such as:

- **Phishing** – stealing student credentials.
- **Brute-force attacks** – guessing passwords.
- **SQL Injection** – attempting unauthorized database access.
- **XSS** – injecting malicious scripts into the web application.
- **DoS/DDoS** – making the examination service unavailable.

The module lists these among common attack vectors and their prevention methods.

5. Possible Impacts

A successful attack may cause:

- Leakage of examination papers.

- Modification or loss of student answers and marks.
- Unauthorized access to student information.

6. Mitigation Measures

The university can reduce these risks by implementing:

- Strong passwords and **MFA**.
- Role-based access control.
- Encryption of sensitive data.
- Audit logs and continuous monitoring.

Explain Authentication, its factors and types.

(Module 1 – Faculty Important Topic; related to Question 7)

Authentication

Authentication is the process of verifying the identity of a user before allowing access to a system or resource.

Authentication Factors

1. **Something You Know** – Password, PIN or security answer.
2. **Something You Have** – Smartphone, smart card or security token.
3. **Something You Are** – Fingerprint, face or other biometric characteristic.
4. **Somewhere You Are** – Location-based verification.
5. **Something You Do** – Behavioural characteristics such as typing patterns or other user actions.

Types of Authentication

- **Single-Factor Authentication (SFA):** Uses one authentication factor.
Eg: Password only.
- **Two-Factor Authentication (2FA):** Uses two different authentication factors.
Eg: Password + OTP.
- **Multi-Factor Authentication (MFA):** Uses two or more authentication factors for stronger security.
Eg: Password + OTP + fingerprint. Example

Authentication helps ensure that only legitimate users gain access to information systems and resources.



Q3. Explain the difference between Qualitative and Quantitative Risk Assessment Methods.

Answer:

Risk assessment methods are used to identify, analyze, and evaluate the level of risk associated with data privacy and security.

Basis	Qualitative Risk Assessment	Quantitative Risk Assessment
Meaning	Assesses risk using descriptive categories.	Assesses risk using numerical values.
Measurement	Uses terms such as Low, Medium, High.	Uses probabilities, percentages, or monetary values.
Nature	Subjective and based on expert judgment.	More objective and data-driven.
Data required	Requires less historical/statistical data.	Requires sufficient numerical or statistical data.
Calculation	Usually does not involve complex calculations.	Involves mathematical calculations and statistical analysis.
Accuracy	Gives a general indication of risk level.	Provides a more precise estimate of risk.
Time	Faster and easier to perform.	Usually more time-consuming.
Example	A dataset may be classified as having High re-identification risk because many records have unique combinations of QIs.	Re-identification risk may be estimated as 20% based on uniqueness or probability calculations.
Use	Useful for quick risk identification and prioritization.	Useful when precise measurement and

Basis	Qualitative Risk Assessment	Quantitative Risk Assessment
		comparison of risks are required.
Limitation	Results can depend on the assessor's judgment.	Requires reliable data and appropriate calculations.

Q7. Analyze the role of Penetration Testing in identifying security weaknesses before they are exploited by attackers.

Answer:

Penetration testing (Pen Testing) is a security testing method in which authorized testers simulate real-world attacks on a system, network, or application to identify security weaknesses before actual attackers can exploit them.

Role of Penetration Testing:

1. **Identifies Vulnerabilities:** Finds weaknesses such as insecure configurations, outdated software, weak authentication, and vulnerable applications.
2. **Simulates Real Attacks:** Testers use controlled attack techniques to understand how an actual attacker could compromise the system.
3. **Finds Exploitable Weaknesses:** It helps determine which vulnerabilities can actually be used to gain unauthorized access or sensitive information.
4. **Tests Security Controls:** Firewalls, authentication mechanisms, access controls, and other security measures can be tested for effectiveness.
5. **Prevents Data Breaches:** Finding weaknesses early allows organizations to fix them before attackers exploit them.
6. **Helps Prioritize Risks:** Vulnerabilities can be analyzed based on their potential impact so that important weaknesses can be addressed first.
7. **Improves Overall Security:** The findings help organizations strengthen configurations, patch systems, and improve security practices.

Example:

Suppose a company's web application has a vulnerable login mechanism. During penetration testing, an authorized tester discovers that the weakness could allow

unauthorized access. The organization can fix the vulnerability before a real attacker discovers and exploits it.